

LambdaTrace: Serverless Security Impact Analysis and Vulnerability Prioritization

Project Proposal

Project Advisor:
Sukhan Amir

Group Members:

Nabiha Noor Khalique	23L-0967
Saarah Tauseef	23L-0552
Ayesha Ameer	23L-0765

National University Of Computer and Emerging Sciences
Department of Computer Science
Lahore, Pakistan

Abstract

Serverless applications, such as those built using AWS Lambda, rely heavily on third-party software dependencies and cloud services. A vulnerability in a dependency can therefore affect multiple functions and resources depending on how the application is structured. Conventional vulnerability metrics such as the Common Vulnerability Scoring System (CVSS) and Exploit Prediction Scoring System (EPSS) provide useful information about vulnerability severity and exploit likelihood, but they do not fully consider the architecture and context of a serverless application. This project proposes **LambdaTrace**, a security-analysis platform for AWS Lambda applications that combines vulnerability information with serverless-specific architectural context. The system will discover Lambda functions, dependencies, shared Layers, IAM permissions, triggers, and selected connected resources, and represent their relationships in a security graph. Vulnerabilities will then be prioritized using both conventional vulnerability scores and contextual factors such as function exposure, affected functions, shared Layer usage, IAM privileges, and access to sensitive resources. To evaluate the approach, controlled Lambda application scenarios will be developed in which architectural conditions can be systematically varied. The architecture-aware prioritization approach will be compared with CVSS-only and CVSS-plus-EPSS baselines to investigate whether serverless architectural context improves vulnerability prioritization.

1. Introduction

Serverless computing has become an increasingly common approach for developing cloud applications because it allows developers to deploy individual functions without managing traditional servers. AWS Lambda is one of the widely used serverless platforms. However, Lambda applications often depend on third-party packages, shared Layers, IAM permissions, APIs, event triggers, and other cloud resources, creating security relationships that differ from those found in conventional applications. A vulnerability in a software dependency does not necessarily have the same security impact in every Lambda application. For example, the same vulnerable package may be present in two functions, while one function is publicly accessible and has permission to modify a sensitive storage resource and the other is an internal function with limited permissions. When used without application-specific context, conventional vulnerability scores may assign the same severity to the same vulnerability even though its potential impact within different application architectures may differ.

LambdaTrace aims to investigate whether incorporating this serverless-specific context can improve vulnerability prioritization. The system will analyze the architecture of controlled AWS Lambda applications and map vulnerabilities to the functions and resources that may be affected. It will then produce an interpretable priority ranking that considers conventional vulnerability scores together with serverless architectural characteristics. The project will also provide an experimental benchmark for comparing three approaches: CVSS-only, CVSS combined with EPSS, and architecture-aware prioritization using serverless context. The purpose is not to replace existing AWS security services or predict attacks with certainty, but to investigate whether architectural information provides additional value when deciding which vulnerabilities should receive attention first.

2. Goals and Objectives

The main objectives of the project are:

1. Develop controlled AWS Lambda applications containing known vulnerable dependencies and different architectural configurations.
2. Automatically discover relevant Lambda architecture information, including dependencies, Layers, IAM permissions, triggers, and potentially reachable resources.
3. Collect vulnerability information from sources such as NVD and OSV and obtain associated CVSS and EPSS scores
4. Build a security graph that represents relationships between vulnerabilities, dependencies, Lambda functions, Layers, IAM roles, triggers, and resources.
5. Develop an interpretable vulnerability prioritization approach that incorporates serverless-specific contextual factors such as exposure, Layer sharing, affected functions, IAM permissions, and resource access.
6. Create a benchmark to compare CVSS-only, CVSS-plus-EPSS, and architecture-aware prioritization.
7. Evaluate the approaches through controlled experiments and present the results through a web-based dashboard.

3. Scope of the Project

The project will focus specifically on **AWS Lambda-based serverless applications**. The system will analyze application architecture and software dependencies rather than attempting to cover every possible cloud security issue. The proposed platform will support discovery of Lambda functions, their dependencies and Layers, associated IAM roles and permissions, selected API or event triggers, and selected resources such as Amazon S3 and DynamoDB. Vulnerability information will be obtained from established vulnerability databases and mapped to affected dependencies and functions.

A security graph will be used to represent the relationships between application components and vulnerabilities. Based on this information, LambdaTrace will generate vulnerability priorities using both conventional scores and serverless-specific contextual information. The research component will use controlled Lambda scenarios where factors such as public exposure, shared Layers, IAM privileges, and resource access can be varied systematically. This will allow the project to evaluate whether architectural context changes vulnerability prioritization compared with conventional approaches.

The project will use synthetic or controlled environments and will not involve exploiting vulnerabilities in production systems or handling real sensitive data. Features such as automated remediation, multi-cloud support, continuous enterprise monitoring, and advanced

machine-learning models are outside the core scope and may only be considered as future extensions.

4. Initial Study and Work Done so Far

As far as our research is concerned, existing work has explored graph-based approaches for connecting software dependencies with vulnerability information and identifying vulnerable components through dependency relationships [1]. Propagation-based approaches have also been proposed to assess how the impact of a vulnerability can extend beyond its individual CVSS severity [2]. Furthermore, studies of public serverless repositories have identified security issues including outdated dependencies and insecure configurations [3], while graph-based reachability analysis has been used to examine IAM policies and access relationships in serverless applications [4]. Other research has also investigated security threats in serverless environments through dedicated security analysis approaches for detecting compromised serverless functions [5]. However, based on our initial study, we have not identified an approach that systematically evaluates vulnerability prioritization using the combined architectural context of AWS Lambda applications, such as function exposure, shared Layers, affected functions, IAM permissions, and potentially reachable resources. Our target is to develop LambdaTrace, a security-analysis platform that uses this serverless-specific context to prioritize vulnerabilities and evaluates its effectiveness against CVSS-only and CVSS-plus-EPSS approaches. So far, we have conducted an initial study of existing approaches to vulnerability analysis, serverless security, and graph-based security analysis, and have identified the main architectural factors that may be relevant to serverless vulnerability prioritization.

References

[1] H. Xia, J. Gluck, S. Simsek, D. Sastre Medina, and D. Starobinski, “VDGraph: A Graph-Theoretic Approach to Unlock Insights from SBOM and SCA Data,” *arXiv preprint arXiv:2507.20502*, 2025.

[2] B. Ruan, Z. Lin, J. Liu, C. Zhang, K. Ji, and Z. Liang, “Propagation-Based Vulnerability Impact Assessment for Software Supply Chains,” in *Proceedings of the 40th IEEE/ACM International Conference on Automated Software Engineering (ASE)*, 2025, pp. 65–77.

[3] E. Marin, J. Kim, A. Pavoni, M. Conti, and R. Di Pietro, “The Hidden Dangers of Public Serverless Repositories: An Empirical Security Assessment,” in *Computer Security – ESORICS 2025*, 2026, pp. 382–401.

[4] I. Polinsky, P. Datta, A. Bates, and W. Enck, “GRASP: Hardening Serverless Applications through Graph Reachability Analysis of Security Policies,” in *Proceedings of the ACM Web Conference 2024 (WWW ’24)*, 2024, pp. 1644–1655.

[5] L. Ben-Shimol, D. Lavi, E. Klevansky, O. Brodt, D. Mimran, Y. Elovici, and A. Shabtai, “Detection of compromised functions in a serverless cloud environment,” Computers & Security, vol. 150, 2025, Art. no. 104261.